

1/38

File No.: EXP202318430

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On September 28, 2022, the Spanish Agency for Data Protection received Report No.

***REPORT.1 from the LOCAL POLICE OF THE CITY COUNCIL OF LA PALMA (hereinafter, the LOCAL POLICE).

The LOCAL POLICE submitted a report dated September 22, 2022, prepared by agents of the Local Police, which revealed the discovery of abandoned correspondence containing personal data, totaling 1,404 letters, bearing the logo of the company HISPAPOST S.A. (hereinafter HISPAPOST). This entity was contacted by the agents, who acknowledged that the found correspondence should have been delivered by employees of CORREO INTELIGENTE POSTAL SL (hereinafter CI POSTAL), without understanding the reason why the delivery was not carried out and the correspondence was abandoned.

The letters belonged to several sending companies, including La Caixa, BBVA, Energía XXI, and Endesa.

On September 13, 2022, a representative of CI POSTAL (A.A.A.) visited the LOCAL POLICE premises, and when shown the found letters, recognized the logo of his company, stating in his declaration that he was unaware of the reason why the correspondence had not been delivered. The letters dated from the months between February and May 2022. This person claimed that this correspondence should have been delivered among four workers, two of whom were no longer employed and two who were still working and had delivered their respective portions, stating that since it was ordinary correspondence, it is impossible to ascertain which of the four delivery workers failed to perform their duties.

On September 22, 2022, this same representative of CI POSTAL returned to the police premises after being summoned again by the police. During this act, he was handed over the correspondence, a total of 1,404 letters from the sending companies with the following distribution: La Caixa (596 letters), BBVA (57 letters), Naturgy (33 letters), Energía XXI (295 letters), Imagin (59 letters), Endesa (307 letters), MasMovil (1 letter), Telefax (3 letters), Totem (3 letters), Laboral Kutxa (1 letter), PSA (1 letter), Yoigo (1 letter), Orange (6 letters), Pra Group (1 letter), Jazztel (2 letters).

Record of HISPAPOST September 13, 2022

AFFECTED COMPANY

FOUND LETTERS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/38

LA CAIXA

596

BBVA

57

NATURGY

33

ENERGÍA XXI

295

IMAGIN

59

ENDESA

307

MASMOVIL

1
TELEFAX
3
LABORAL KUTXA
1
PSA FINANCIAL
1
YOIGO
1
ORANGE
6
PRA GROUP
1
JAZZTEL

2

On November 17, 2022, the Spanish Agency for Data Protection received a new complaint from the Delegation of the Government in the Balearic Islands, which forwarded a document sent by the Superior Police Headquarters of the Balearic Islands regarding the location of a total of 5,354 letters abandoned in two different locations in La Palma, for which the company HISPAPOST was responsible, managing the delivery through its distributor in La Palma, CI POSTAL.

- A report from the Local Police dated October 17, 2022, is attached, stating: "Commissioned (...), two journalists located on the Son Hugo road at the height of the Soller train tracks numerous letters from banking entities, mobile phone companies, etc. Most of which were found closed and a few manipulated."

- The report prepared by the Police and addressed to the Investigating Court is also attached, in which it is stated:

- That contact was made with HISPAPOST, and they claimed to be the responsible company for the shipments, but it was CI POSTAL that managed the final distribution of postal mail in La Palma. It includes screenshots of emails exchanged between the Police and HISPAPOST, from which the following is extracted:

- On October 19, 2022, the National Police group asked HISPAPOST about the delivery company and communicated the number of letters located and the names of the companies to which they belong.

- Screenshot of the response email from HISPAPOST to the previous email, dated October 21, 2022, stating that the shipment by HISPAPOST was through its distributor in La Palma (CI POSTAL).

- That it has not been possible to ascertain the identity of the author or authors of the abandonment of the correspondence and that the letters were handed over to an authorized representative of HISPAPOST.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/38

This is a total count of 5,354 letters with the following distribution of affected companies and located letters:

Notified to HISPAPOST on October 19, 2022

****COMPANY****

****LETTERS****

****COMPANY****

****LETTERS****

ENERGY XXI

1,420

LEXER

1
ENDESA
1,485
EQUIFAX
42
NATURGY
170
TELEFAX
4
GAES
1,470
PSA FINANC.
5
VODAFONE
16
INVEST CAPITAL
4
JAZZTEL
51
TR3A
8
YOIGO
5
ZOLVA
29
ORANGE
21
AYTO MADRID (TAX AGENCY)
1
MASMOVIL
17
AYTO SEVILLA (TAX AGENCY)
5
BANCO SABADELL
240
MC ABOGADOS
3
CAIXABANK
40
ASISA
2
BBVA
197

A new official report was sent to the Investigating Court on October 16, 2022, detailing a new intervention carried out by the Police in which approximately 3,000 usable letters, unopened, were seized. They were collected and stored in plastic bags, leaving behind others that were partially burned or mixed with garbage. No details are provided about the companies to which these letters belong as they were made available to the Court.

In relation to this incident, this Agency was notified by various responsible parties of treatments affected by the postal abandonments of the following security breaches:

1. The responsible party BANCO SABADELL SA reported the breach on October 20, 2022.
2. The responsible party PSA FINANCIAL SERVICES reported the breach on October 21, 2022, and

November 16, 2022.

3. The responsible party ASNEF-EQUIFAX SERVICIOS INFORMACIÓN reported the breach on October 21, 2022, and November 15, 2022.

4. The responsible party INTRUM SERVICING SPAIN reported the breach on October 24, 2022, and November 21, 2022.

5. The responsible party VODAFONE ESPAÑA reported the breach on October 27, 2022, and November 25, 2022.

6. The responsible party PRA IBERIA SL reported the breach on November 1, 2022.

7. The responsible party CABOT FINANCIAL SPAIN SA reported the breach on November 3, 2022, and December 1, 2022.

8. The responsible party INVESTCAPITAL LTD reported the breach on November 18, 2022.

9. The responsible party EOS SPAIN SL reported the breach on November 17, 2022, and December 7, 2022.

****SECOND:**** In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to CI POSTAL for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on November 16, 2022, as stated in the certificate in the file.

On December 5, 2022, this Agency received a written response to the previous transfer submitted by the company QUICK LOPD SL in its capacity as Data Protection Officer of CI POSTAL.

From the analysis of the response, the following statements are extracted:

- "At CIPOSTAL, we became aware of this incident on September 9, 2022, when the company HISPAPOST, for whom we provide postal mail service in Palma de Mallorca, informed us that the local police had contacted them to indicate that two bags of garbage containing correspondence with their logo had been collected."

- "Regarding the postal code of the documents found, and the dates of the same, from CIPOSTAL we identified the two individuals responsible for that delivery and disciplinary measures were taken, as they are no longer working for the company."

- "After receiving the notice, the person in charge of CIPOSTAL in Palma de Mallorca went to the local police station, we verified that there were two bags with unopened correspondence, and after the local police counted the letters, they handed us a copy of the complaint along with the 1,404 ordinary letters collected, all from the postal code (...) of various clients and dated May 2022."

- "Immediately, the rest of the staff was informed, as well as the central office, so that they could detail the COMPLIANCE department, in order that in addition to the training sessions already offered previously, a new training session would be conducted to serve as a reinforcement for the prevention of similar incidents. The Data Protection Officer was informed to carry out an initial assessment of the facts and analyze whether the rights and freedoms of the affected individuals have been violated."

- "This is a premeditated security incident by internal personnel of the organization that has posed a risk to the availability and confidentiality of the correspondence that was to be safeguarded and delivered, violating internal regulations and the duty of custody under postal legislation. A total of 1,404 sealed letters have been recovered from a population census of the city of Palma de Mallorca of 500,000 people, in which during the..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/38

During the period from January to October 2022, 2,470,632 letters were distributed. We consider that the percentage of correspondence exposed to third parties without consent, although a concerning fact, has been residual due to the volume of correspondence distributed during the January – October

2022 period. The data that was exposed to third parties consists of basic identifying information (name and surname) along with contact details such as the postal address; this was postal correspondence retrieved without evidence of tampering. In contrast with the police, no tampered letters or empty envelopes have been found that would suggest access to other types of information.”

-

“Following the evaluation conducted by CIPOSTAL regarding the incident, it was considered that no damage could occur to the rights and freedoms of the individuals whose data was exposed, as no high or very high risk to the rights and freedoms of the affected subjects was perceived. There is no record of any of the identified damages materializing, at the degree indicated in the previous question. Therefore, it is assessed as UNLIKELY that the aforementioned damage will materialize for the affected individuals with the indicated severity.”

-

Regarding the reactive actions and measures adopted by this company, it is stated:

☐ “Firstly, the employees involved in the incident were dismissed, and the rest of the staff was gathered to remind them of their obligations regarding the custody of correspondence and the consequences of non-compliance.

☐ In addition to the training sessions previously offered, new training has been conducted to serve as reinforcement for the prevention of similar incidents.

☐ A reminder to all classification and delivery personnel through meetings and individualized writings regarding the legal repercussions of retaining, storing, concealing, opening, or destroying any postal shipment.

☐ Monitoring of the delivery personnel regarding their work, asking about the streets where they were delivering and verifying this with the distribution we have prepared for them.

☐ We have held meetings and conversations with the Data Protection Delegate of HISPAPOST so that they can inform the ultimate data controllers, who are the clients sending the retrieved correspondence.”

-

Regarding the preventive measures implemented, it states:

☐ “As a postal delivery company, the measures aimed at preventing the risks arising from abandonment or non-delivery of correspondence are focused on the training and commitment of the workforce beyond the implementation of technological solutions.”

☐ “During the onboarding process of employees, a welcome pack is provided containing a compendium of rules and protocols that must be complied with.” To substantiate this claim, the following documents are provided:

☐ An Ethical Code and Conduct, with an implementation date of April 16, 2018.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/38

☐ Corporate policies regarding obligations and prohibited conduct, with an implementation date of April 16, 2018.

☐ Description of the whistleblowing channel, with an implementation date of April 16, 2018.

☐ Disciplinary and sanctioning regime, with an implementation date of April 16, 2018.

☐ Protocol for delivery personnel, with an implementation date of October 20, 2020.

☐ The employee is required to sign a confidentiality commitment. To substantiate this, a template or model of this commitment is provided as an attachment; however, no signed documents are submitted.

☐ An informational communication from the general director dated November 19, 2021, is attached, conveying information about the responsibility not to deliver notifications or letters and/or to misuse them; however, there is no evidence of this communication being made available to employees.

- The Record of Processing Activities (RAT) is provided, containing the activity "Parcel delivery and postal service" with the following information: data controller, source of the data, affected parties, categories of personal data, transfers, data processors, legitimacy, retention periods, international

transfers.

- Regarding the notification of the incident, it is stated: "It was considered not to notify the affected parties due to the low volume of recovered letters (less than 0.5%) compared to the total delivered and because they were recovered without signs of improper handling. From the moment the incident was known, as sub-processors, we informed and collaborated at all times with the data controller (HISPAPOST) so that they could report to the different data controllers, with the aim that they could assess the notification of the security breach. It was considered that no harm could occur to the rights and freedoms of the individuals whose data were exposed, which is why the security breach was not communicated to the affected parties in accordance with Article 34 of the GDPR, as it was not deemed that there could be a high or very high risk to the rights and freedoms of the affected subjects; however, this was a decision that we understood should be made by the Data Controller, given that we were talking about postal delivery which involves non-automated handling."

- Regarding the measures to prevent the incident from happening again, it is stated: "We are studying and evaluating whether there is any type of technological solution that allows us to confirm that the mail has been deposited in a mailbox. The training and awareness plan for the work team has been reinforced to avoid future incidents."

THIRD: As a consequence of the report by the LOCAL POLICE regarding the discovery of a large amount of abandoned correspondence in a vacant lot, as well as the discovery of numerous undelivered letters addressed to individuals, which had apparently been abandoned for several months, and in light of the media coverage, the Director of the Spanish Agency for Data Protection, by Internal Note dated December 28, 2022, urged the General Subdirectorate for Data Inspection to initiate ex officio preliminary investigation actions aimed at substantiating these facts and their authorship.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/38

The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

In relation to the security breaches reported to this Agency, it is noted:

From the breach reported by the responsible party BANCO SABADELL SA, the following is extracted:

- The complaint filed by HISPAPOST with the National Police on October 14, 2022, is attached.
- Description of the incident: "Banco de Sabadell, through communication made by its postal service provider (HISPAPOST) on October 18, 2022, became aware of the existence of several postal shipments to its clients in Palma de Mallorca found in various locations in the municipality discarded by personnel from the company responsible for distribution (CI POSTAL). Once the documentation was recovered, in various states of deterioration, by the law enforcement agencies, it was reviewed by Hispapost, who informed us that 252 shipments from Banco Sabadell to its clients are affected. These shipments, pending verification, could include account movements, balance information, marketing, or any other type of personal and financial information. The facts have been reported."
- Number of affected individuals: 252.
- Date of detection: October 18, 2022.

From the breach reported by the responsible party PSA FINANCIAL SERVICES on October 21, 2022, the following is extracted:

- Description of the incident: "Our data processor, Servinform S.A., became aware through the postal company Hispapost, on October 10, via a video published on social media, that the correspondence handled by another subcontractor was abandoned in public spaces by its personnel in the city of Palma de Mallorca. Due to the type of letters sent, it is identified that approximately 90% corresponds to notifications related to the processes of recovering unpaid debts."

- Date of detection: October 20, 2022.
- Number of affected individuals: 44. The affected individuals will not be notified.
- An incident report dated November 14, 2022, is attached, from which the following statements are obtained:
 - "PSA Finance contracts the services of sending correspondence to SERVIFORM, S.A., which acts as the data processor. Servinform subcontracts the services to HISPAPOST, S.A., which in turn subcontracts the activity for the region of Palma de Mallorca to CI POSTAL, S.L., with these two entities acting as subcontractors of the processing for PSA Finance."
 - On October 18, HISPAPOST received information about the postal shipments that were recovered by the Police, confirming the existence of 5 letters corresponding to PSA FINANCE. The following day, October 19,

8/38
October 2022, SERVIFORM reported the security incident to PSA FINANCE.

□
That 44 shipments have potentially been affected, and it is estimated that approximately 90% of them correspond to notifications related to the processes of recovering unpaid debts.

From the breaches reported by the responsible party ASNEF-EQUIFAX on October 21, 2022, and November 15, 2022, the following is extracted:

- Description of the incident: "ASNEF-EQUIFAX, as the data controller of the ASNEF Bureau, communicates with consumers whose data has been included in said file. On 10/20/2022, HISPAPOST notified that an employee of the company responsible for the distribution of notifications (CI POSTAL, S.L. in Palma de Mallorca) has abandoned, in various locations in Palma de Mallorca, communications that were entrusted to be delivered. The provider initially indicates that the number of affected letters is 187; however, after the analyses carried out, the notifications total 47 notification letters of inclusion and 1 payment request. The actions taken by Equifax have been (regarding the processing for which it is responsible): 1) to cancel the operations of the abandoned notifications that were recovered; 2) as a precautionary measure, all operations whose inclusion notifications may have been potentially compromised (from 1/1/22 to 10/20/22 in the postal codes (...), (...) and (...)) have been canceled; and 3) the registration of these operations has been blocked for 45 days in the ASNEF file."

- Volume of affected: 47.

- Date of breach detection: October 20, 2022.

From the breaches reported by the responsible party INTRUM on October 24, 2022, and November 21, 2022, the following is extracted:

- Description: "INTRUM SERVICING SPAIN has contracted with EQUIFAX a notification sending service, which in turn has subcontracted to Hispapost. On 10/21 at 6 PM, we were informed of an incident that has caused some of the notifications of Prior Requests and inclusion in the bureau not to have been carried out. As measures taken so far by Hispapost, they have ceased working with the company responsible for the distribution of communications in P. de Mallorca and have presented the appropriate legal actions. The actions being carried out by Equifax, of which we will provide information as they are carried out, are as follows: i) determine the number of shipments from Intrum and the details of those that have been sent to the postal codes involved in the indicated months; ii) determine the recipients of the communications that have been included in the ASNEF file; iii) proceed to delete said data from the ASNEF file, if applicable, and the possible blocking of new registrations in ASNEF; iv) determine the claims that the recipients of the involved communications may have made regarding the ASNEF file."

- Volume of affected: 1.

- Date of breach detection: October 21, 2022.

From the breaches reported by the responsible party VODAFONE on October 27, 2022, and November 25, 2022, the following is extracted:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

-
Description: "Postal shipments (correspondence) from various clients have been found abandoned in different areas around the city of Palma de Mallorca. The postal distribution in this area was carried out by CI POSTAL, S.L., acting as a subcontractor for the processing of Hispapost S.A., an entity subcontracted by Equifax Ibérica, S.L., which in turn provides debt collection services to Vodafone as the data processor. The affected letters contain information about the recipient's unpaid debts to Vodafone, including the amount owed. Vodafone was notified by Equifax on October 24, 2022, via email. Vodafone has reviewed the incident and, after analyzing the provider, concluded that the number of potentially affected clients is 361."

-
Detection date: October 24, 2022.

From the breach reported by the responsible party PRA IBERIA SL on November 1, 2022, the following is extracted:

-
Incident description: "We received communication on October 21, 2022, from Equifax Ibérica, S.L.U. (Equifax) informing us of an incident with the correspondence related to the notification letters for inclusion in the Asnef file. Upon reviewing the communication files to Asnef, we confirmed that we have no record of registration, and therefore this incident cannot affect our clients in relation to the communication to the Asnef file. Subsequently, we asked Equifax if the service of sending correspondence to clients of PRA Iberia, S.L.U. (PRA) has also been affected. On October 28, 2022, we received official confirmation from Equifax of the abandonment of correspondence by an employee of a postal operator subcontracted by Equifax (CI POSTAL, S.L. -CI POSTAL-, through Hispapost, distribution in Palma de Mallorca), which affects the correspondence sent by PRA for the postal codes (...), (...) and (...) from January 1, 2022, to October 10, 2022."

-
They state the detection date as: October 28, 2022.

-
It is stated that there are 1,023 potential affected individuals.

From the breaches reported by the responsible party CABOT FINANCIAL on November 3, 2022, and December 1, 2022, the following is extracted:

-
They state the detection date as: November 1, 2022.

-
Volume of affected individuals: 326.

-
They provide a report with the analysis and assessment of the breach, from which the following statements are extracted:

☐

"It has been a security breach that has compromised the confidentiality of the data insofar as third parties may have accessed the information contained in the communication of inclusion in the ASNEF file, as well as the availability, to the extent that there would be an indeterminate number of lost communications that, as of the date of this Closure Report, have not yet been determined."

☐

"EQUIFAX confirms the number of 326 affected letters addressed to debtors."

☐

"Following the criteria of the AEPD, it has been considered that there is a LOW probability that the risks will materialize and that, in any case, the severity of the breach is HIGH."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/38

From the breach notified by the responsible party EOS SPAIN SL on November 17 and December 7, 2022, the following is extracted:

-

Detection date: November 15, 2022.

-

They provide an incident report from which the following statements are extracted:

☐

"Equifax has received 84 physical letters from Hispapost that have been directly recovered from the places where they were abandoned. The Police also have physical letters that are still retained by the authorities as they constitute evidence in the investigation initiated by the competent Investigating Court for the processing of the corresponding criminal procedure. Equifax is unaware of the content of that correspondence in the possession of the Police."

☐

"The affected notifications include both the inclusion notifications made by ASNEF-EQUIFAX to inform debtors of their inclusion in the ASNEF file, as well as notifications of prior payment requests from clients."

-

Potential volume of affected individuals: 1067.

Investigation directed at CI POSTAL SL:

On March 29, 2023, a request for information is made to CI POSTAL, the entity responsible for the final delivery of the correspondence and accountable for the abandonment. The request was marked by the following line of investigation:

-

Obtain a copy of the breach report.

-

Investigate the technical and organizational measures implemented in the organization to ensure the confidentiality of affected workers and the security of the processing in the shipments, specifically for the four workers possibly responsible for the abandonments.

-

Investigate the security measures implemented to ensure the security of the processing carried out in the postal shipments.

-

Investigate the contracts for the assignment or sub-assignment of the affected processing.

This request expired without access to its content on April 9, 2023, and a second reiteration was subsequently carried out via postal mail on June 5, 2023, with the acknowledgment of receipt dated the same June 5, 2023, after access to the Unique Enabled Electronic Address; however, no response is recorded.

On August 23, 2023, it was decided to make a final attempt to request this entity to provide evidence of the preventive measures that existed to ensure the confidentiality of employees, the traceability and monitoring of shipments, as well as the training and awareness activities carried out prior to the breach.

CI POSTAL responds to this last request on August 31, 2023, and from the analysis of their response, the following relevant information is extracted:

-

They provide a document certifying the confidentiality commitments signed by the two workers who from CI POSTAL were considered to be the ones responsible.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/38

responsible for the abandonment of correspondence in public spaces and against whom disciplinary

measures of dismissal were taken.

-

Regarding the accreditation of training actions, they state: "Having conducted basic information and awareness training of 1 hour online to explain the basic concepts in data protection, no training certificates were issued. A 40-hour training for postal delivery personnel with high turnover is not a system suited to the needs of the company, hence the conduct of one-hour informational sessions. However, following the incident in the 2022 exercise, a privacy training manual has been incorporated into the Welcome Pack, which includes basic concepts for their functions, considering that in 99% of cases, the delivery personnel handle data that is consultative, without the ability to record, modify, or delete data." A document with the basic data protection training manual is attached, but the mentioned training session is not accredited.

-

Regarding the accreditation of the measures adopted to ensure traceability and tracking of shipments, they state: "In ordinary postal delivery, which caused the security incident due to the abandonment of correspondence, implementing traceability and tracking measures for the delivery involves a very high level of difficulty. To date, no technological solution has been found that allows confirmation that ordinary mail has been deposited in the mailbox. It should be noted that CIPOSTAL receives large volumes of correspondence from its clients for delivery, without any breakdown of data. We are only provided with batches of correspondence where the only data available is the number of letters to be delivered. Creating delivery teams of two people to control whether the delivery is made or not is an unfeasible solution due to costs."

Investigation directed at the data controller HISPAPOST SA:

On March 30, 2023, a request for information was made to HISPAPOST, marked by the following lines of investigation:

-

Investigate the incident register and the register of activities of treatments affected by the breach.

-

Obtain information on the notification of the breach to this Agency and the communication to the affected parties.

-

Investigate the notifications of the breach to the affected companies and those with which there was a contract of engagement.

-

Investigate the existence of engagement contracts with the affected companies.

-

Investigate the engagement contract with the subcontractor CI POSTAL SL.

-

Investigate the possible risk analysis and the accreditation of the preventive measures implemented.

On April 24, 2023, a response to the previous request was received, from which the following relevant information is extracted:

-

The documented record of the security breach is attached, from which the following statements are obtained:

☐

A total of 7924 postal shipments recovered is stated.

☐

It is not considered that the content of the letters was exposed in any case, therefore the affected data were "name and surname."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/38

of the recipient and postal delivery address.” They claim that the letters have been found in remote locations abandoned, thus ruling out exposure to a large number of people.

☐

They assert that the letters are ordinary shipments (not certified), which eliminates significant consequences for the interested parties arising from the non-receipt of the letter, and that each of their clients (who mostly acted as data controllers) was informed to assess this impact. It was considered that “no damage could occur to the rights and freedoms of the affected individuals.”

☐

They provide the following timeline of events (which only refers to the letters found in October, with no reference in this timeline to the shipment of letters located by the Local Police in September 2022):

☐

On October 10 at 17:20 hours, they receive information about a video published on the internet. The correspondence is recovered by HISPAPOST personnel.

☐

On October 13, 2022, new shipments are located following an alert from a citizen.

☐

On October 14, the incident is reported to the DPO and a complaint is filed with the National Police.

☐

On October 17, 2022, the found correspondence arrives at HISPAPOST facilities in Madrid for analysis and quantification of affected clients. On the same day, October 17, 2022, new findings are discovered by the police and media.

☐

On October 19, detailed information about the shipments recovered by the police is received; the letters are returned to the clients or discarded based on their instructions.

☐

From October 14 to 21, the incident is notified to the affected clients.

☐

It is stated that “the shipments made to the city of Palma de Mallorca do not allow for the traceability control that HISPAPOST applies to its ordinary shipments due to logistical difficulties in transport.”

☐

They provide a list of reactive measures adopted by the company:

☐

Closure of distribution in Palma de Mallorca.

☐

Increase inspections in the delivery network.

☐

Reminder to staff about responsibilities in deliveries.

☐

Avoid working in postal codes where there are no shipments with traceability to be able to evaluate the status of these daily (considering having a minimum number of traceable shipments).

☐

Deployment of internal panelists to monitor correspondence.

☐

Reinforcement in training and awareness of employees.

-

The complaint filed by HISPAPOST on October 14, 2022, is attached; from the analysis of this complaint, the following relevant statements are extracted:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

☐

It is stated: "On October 10, 2022, HISPAPOST receives a message from CI POSTAL in which they send a video taken from Telegram showing a man commenting and filming thousands of letters scattered in a junkyard sent from HISPAPOST, which contain personal data of clients (Naturgy and Endesa among others)... that these letters were collected by the distributor in Mallorca on October 11, 2022, and were sent back on October 13, 2022, to the reporting company."

☐

"On October 13, 2022, a message is received from the company CaixaBank informing that one B.B.B. has found approximately 4000 letters addressed to CaixaBank in perfect condition, which were thrown by an unknown individual from a vehicle at 19:00 hours on October 10, 2022."

-

The Record of Processing Activities (RAT) of HISPAPOST as a data processor, updated to December 14, 2022, is provided. From the analysis of this RAT, it is concluded that HISPAPOST carried out processing on behalf of the following controllers:

☐

For the data controller AMPLIFÓN IBÉRICA SAU:

☐

Description of processing: Postal distribution service.

☐

Authorization for subcontracting exists: YES.

☐

For the data controller BANCO SABADELL SA:

☐

Description of processing: Provision of postal services.

☐

Authorization for subcontracting exists: YES.

☐

For the client data controller BBVA SA:

☐

Description of processing: Mail, Telegram, and Burofaxes, National and International Messaging.

☐

Authorization for subcontracting exists: YES.

☐

For the client data controller CAIXABANK FACILITIES MANAGEMENT SA:

☐

Description of processing: Collection and home delivery of correspondence for CaixaBank.

☐

Authorization for subcontracting exists: YES.

☐

For the data controller EQUIFAX IBERICA SL (B80855398):

☐

It is stated that this client acts as the Data Controller of the personal data processed.

☐

Description of processing: Postal services.

☐

Authorization for subcontracting exists: YES.

☐

For the client data controller ENDESA SA:

☐

Description of processing: Postal services.

☐

Authorization for subcontracting exists: YES.

☐

For the client data controller NATURGY CLIENTES SA:

☐

Description of processing: Postal services.

☐

Authorization for subcontracting exists: YES.

☐

For the client SERVIFORM SA:

☐

It is stated that this client acts as the Data Processor of the personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/38

☐

Description of processing: postal distribution for PSA

FINANCIAL SERVICES SPAIN, E.F.C., S.A (acting as Data Controller).

☐

There is authorization for subcontracting: YES.

☐

For the data controller client AYUNTAMIENTO DE MADRID (General Directorate of Contracting and Services):

☐

The client is the Data Controller.

☐

Description of processing: Postal distribution for the City of Madrid and its Autonomous Bodies.

☐

Data: identifying data (name, surname, and postal address), corresponding to the processing activity "Executive Collection."

☐

There is authorization for subcontracting: YES.

☐

For the data controller client GRUPO MEDINA CUADROS (MC ABOGADOS SL + TELEFAX):

☐

The client is the Data Controller.

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

For the data controller client AYUNTAMIENTO DE SEVILLA (Seville Tax Agency):

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

For the data controller client ASOCIACIÓN ESPAÑOLA CONTRA EL CÁNCER:

☐

Description of processing: postal services.

☐

There is authorization for subcontracting: YES.

☐

Retention period 3 months.

-
Regarding the notification of the breach, it states: "Hisapost, as the data processor involved in the incident, informed its clients (Data Controllers) about the incident that occurred so that they could assess the incident and determine if it could be considered a security breach, and if applicable, make the appropriate communication of the security breach to the Data Protection Agency."

-
A document is attached with a report drafted by the DPO of HISPAPOST, the company Ascendia Reingeniería Y Consulting, S.L., signed on April 21, 2023, containing the assessment of the breach.

-
Regarding the notification of the breach to all affected companies acting as data controllers of the affected personal data (clients of HISPAPOST), the following is documented:

☐
Notification made to the data controller ASOCIACIÓN ESPAÑOLA CONTRA EL CÁNCER (AECC), providing a screenshot of the email sent on October 20, 2022.

☐
Notification made to the AGENCIA TRIBUTARIA DE SEVILLA providing a screenshot of the email sent on October 20, 2022.

☐
Notification made to ASISA providing a screenshot of the email sent on October 19, 2022. This notification was first made to the client SERVIFORM on October 19, 2022; this client acts as the data processor for the data controller ASISA, and it is documented that on the same day, October 19, 2022, the notification with the incident report was sent to this data controller.

☐
Notification made to BBVA providing a screenshot of the email sent on October 20, 2022.

☐
Notification made to CAIXABANK providing a screenshot of the email sent on October 19, 2022. The information provided regarding this notification included the following relevant statements for the investigation:

☐
"On 10/13/2022, we received a communication from CaixaBank, notifying that a person presented themselves at the CaixaBank office (...), indicating that they had seen someone throwing correspondence in a location in the municipality. CaixaBank staff retrieved the mailings. On 10/14/2022, we went to the Territorial Directorate of Caixa in Palma de Mallorca, obtained the phone number of the person who initially communicated to CaixaBank the location of the discovery of documents, located the point where the correspondence appeared, and collected the remaining mailings from other clients not associated with CaixaBank."

☐
"On 10/17/2022, the recovered correspondence (not in good condition) arrived at the Hispapost Madrid facilities for analysis and quantification of clients and the number of affected mailings. In this analysis, 92 communications from CaixaBank were identified in poor condition."

☐
"On 10/19/2022, we received information about mailings recovered by the Police in these days. Mailings corresponding to CaixaBank are 40, which as soon as they are sent to us by the authorities, we will forward to your facilities."

☐
Notification made to ENDESA providing a screenshot of emails sent on October 13, 2022, and October 20, 2022.

☐
Notification made to EQUIFAX providing a screenshot of the email sent on October 20, 2022. Attached to this email was a report of the incident, which is also provided; from its analysis, the following relevant statements are obtained:

☐
"There were 92 recovered mailings: 46 letters from Equifax, 2 letters from Sabadell, 22 letters from

Intrum, 1 letter from PraGroup, 1 letter from Link Finanzas, 3 letters from BBVA, 1 letter from TEAM4, 2 letters from Procobro, 6 letters from Vodafone.”

□

Notification made to GAES (formerly known as AMPLIFON IBÉRICA SAU) providing a screenshot of the email sent on October 18, 2022.

□

Notification made to GRUPO MASMOVIL providing a screenshot of the email sent on October 20, 2022.

□

Notification made to NATURGY providing a screenshot of the email sent on October 13, 2022, with a general statement about the incident.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/38

- Notification made to GRUPO ORANGE providing a screenshot of the email sent on October 20, 2022.

- Notification made to PSA FINANCIAL providing a screenshot of the email sent from the address ***EMAIL.1 on October 20, 2022. According to the RAT, HISPAPOST acts as the data processor for SERVIFORM, and this, in turn, acts as the data processor for the postal distribution of the responsible party PSA FINANCIAL SERVICES.

- Notification made to BANCO SABADELL providing a screenshot of the email sent on October 18, 2022.

- Notification made to MC ABOGADOS Y TELEFAX providing a screenshot of the email sent on October 21, 2022.

- Notification made to TR3A providing a screenshot of the email sent on October 20, 2022, the email is sent from the address ***EMAIL.2 to the recipient ***EMAIL.3. The present inspector confirms that this responsible party is NOT listed in the RAT of HISPAPOST as a processor.

- A copy of the data processing agreement between HISPAPOST and CI POSTAL is attached; from its analysis, the following relevant information is extracted:

- The date of signing the contract is January 10, 2022, and it details the types of data affected by the agreement, the categories of data subjects, the processing operations, the international transfers, and the data of both DPOs.

- It is stated that HISPAPOST has the status of data processor while CI POSTAL is a sub-processor, with THE CLIENT OF HISPAPOST acting as the data controller of the data affected by the agreement.

- The obligations of the provider CI POSTAL as a sub-processor are detailed, among which the following stand out:

- Ensure that the persons authorized to process personal data commit expressly and in writing to respect confidentiality and comply with the corresponding security measures, of which they must be duly informed.

- Ensure the necessary training in personal data protection for the authorized persons.

- According to Article 32 of the GDPR, CI POSTAL commits to adopting the necessary measures to prevent alteration, loss, processing, or unauthorized access to the personal data of HISPAPOST's clients, taking into account the state of technology, the nature of the data, and the risks involved, whether arising from human action or from physical or natural means. CI POSTAL states that it has a Privacy Manual in which the technical and organizational measures to be implemented are determined.

- CI POSTAL will notify HISPAPOST without undue delay and as quickly as possible and in any case before 24 hours, via email to protecciondedatos@servinform.es of the security breaches unless it is unlikely to pose a risk to the rights and freedoms of natural persons.

- It is the responsibility of HISPAPOST or its client (data controller) to notify the breaches to the AEPD and to the data subjects.

- According to the risk assessment carried out by HISPAPOST's client, and as established in Article 28 of the GDPR, CI POSTAL must implement at least the security measures corresponding to the medium level in accordance with the provisions of the regulation developing the LOPD (RLOPD) RD 1720/2007, unless other measures are specified in its replacement.
- Copies of the data processing agreements that existed formalized between HISPAPOST and each of its clients to whom it provided postal distribution services and who were affected by the breach are provided, confirming:
 - A copy of the processing agreement with the data controller ASISA, signed on January 1, 2022.
 - A copy of the processing agreement with AYUNTAMIENTO DE MADRID, signed on January 26, 2021. This contract specifies the authorization to subcontract the service with CI POSTAL.
 - A copy of the processing agreement with the data controller BBVA, signed on April 13, 2021.
 - A copy of the processing agreement with the data controller CAIXABANK, signed on July 19, 2019.
 - A copy of the processing agreement with EQUIFAX IBERICA SL, signed on April 1, 2019.
 - A copy of the processing agreement with AMPLIFON IBERICA SAU A59198770 (former name of GAES), signed on March 30, 2021. Among its clauses, HISPAPOST is authorized to subcontract the services with all members of its distribution network where it does not have its own coverage.
 - A copy of the processing agreement with SERVIFORM, signed on January 15, 2019.
 - A copy of the processing agreement with BANCO SABADELL, signed on February 24, 2022.
 - A copy of the processing agreement with ENDESA, signed on February 1, 2022.
 - A copy of the processing agreement with NATURGY CLIENTES SA, signed on March 31, 2022. The subcontracting of CI POSTAL is expressly authorized in the contract.
- In response to the request, a document containing a report of the Data Protection Impact Assessment (DPIA) on the postal distribution processing activity is also provided.
- A document containing the list of reactive measures implemented by HISPAPOST following the security breach is provided.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 18/38

On June 20, 2023, a second request for information was decided to be made to HISPAPOST marked by the following line of investigation:

- It is requested to verify whether notifications of the security breach were made to the responsible parties (clients) affected by the abandonments identified by the Local Police in September 2022, of which they were aware on September 13, 2022, according to the police report.
- Clarification is requested regarding some of the measures implemented to ensure the traceability of shipments.
- Evidence is requested of the reactive measure adopted (...), specifically, accreditation of the results obtained for the distributor CI POSTAL.

On June 29, 2023, a response to the previous request was received, from which the following statements are extracted:

- "On September 13, personnel from CI Postal went to the police station and identified the letters (1404 letters from different clients), and on September 22, CI Postal collected the letters from the Local Police station in Palma; no letter had been opened or tampered with."
- "After evaluating the factors involved in the incident (during the last week of September and the first week of October, as the information was obtained): the limited number of affected letters, their good condition without being opened or tampered with, the possibility of resuming distribution, the location of the finding in a remote and inaccessible place (which reduces the likelihood of them being accessible), the type of letters which were ordinary mail (which rules out contents that could generate significant consequences for the interested parties), the intentional cause by CI Postal employees; it was considered improbable that damage could occur to the rights and freedoms of the individuals whose data were exposed, as no high or very high risk to the rights and freedoms of the affected parties was

perceived, and at that moment, communication to the affected clients was not deemed necessary. Communication to those clients was made days later regarding the new findings that occurred in October (detected on October 11, 2022)."

- "The sensitive postal codes or those with traceability defects are all of Palma de Mallorca (the only city in the Balearic Islands that Hispapost distributed), with CI Postal being the sub-processor of the data, and due to the impossibility of controlling the service, it was decided not to resume the service from the occurrence of the incident."

- "Ordinary shipments do not allow for any type of direct traceability to be applied either by Hispapost or by any postal operator. The processing of this type of shipment is done manually (on paper) and the only data that Hispapost manages are the volumes of clients and letters. Regarding the traceability control that Hispapost applies for this type of shipment, it is done indirectly through the following means:

- Indirect control through certified shipments

- Control of complaints

- Periodic inspections."

- Evidence of some periodic inspections carried out in distribution centers is provided, along with the manual they use to carry them out.

- In relation to our request for them to provide evidence of the awareness actions they had obtained from the sub-processor CI POSTAL, they provide:

- Evidence of an informative communication directed to the workers of CI POSTAL on November 19, 2021, regarding the consequences of non-compliance with regulations, the ethical code, and the COMPLIANCE program.

- Evidence of a training session in December 2021 with the following content, without specifying the duration of the training: Ethical Code, Confidentiality Agreement, Criminal Risks at Work, Disciplinary Regime, and Whistleblower Channel.

FIFTH: According to the report collected from the AXESOR tool, the entity CI POSTAL is a medium-sized company established in 2010, with a business volume of 6,274,271 euros in 2022.

SIXTH: On December 22, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

SEVENTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and after the period granted for the formulation of allegations had elapsed, it has been confirmed that no allegations have been received from the accused party. Article 64.2.f) of the LPACAP - a provision of which the accused party was informed in the initiation agreement of the procedure - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts in which the accusation was specified, the infringement of the GDPR attributed to the accused party, and the sanction that could be imposed. Therefore, considering that the accused party has not formulated allegations to the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/38

In view of all the actions taken by the Spanish Agency for Data Protection in the present procedure, the following facts are considered proven,

PROVEN FACTS

FIRST. The entity HISPAPOST is a company dedicated to the provision of postal services or postal distribution, undertaking all tasks involved in such services, from collection to delivery to the recipients of the postal items in question.

To this end, it has formalized contracts for the provision of postal services with numerous entities, including ASISA, AYUNTAMIENTO DE MADRID, BBVA, CAIXABANK, EQUIFAX IBERICA SL, AMPLIFON IBERICA SAU (GAES), SERVIFORM, BANCO SABADELL, ENDESA, and NATURGY CLIENTES SA.

From the perspective of personal data protection, in all the aforementioned contractual relationships, the entity HISPAPOST acts as the data processor, while the client entities of HISPAPOST are responsible for the processing of personal data.

SECOND. For the development and execution of these postal services, HISPAPOST subcontracts these services or parts of them with other entities, especially for those locations where its distribution network does not have its own coverage.

In such relationships that HISPAPOST formalizes, the subcontracting entity acts, from the perspective of personal data protection, as a sub-processor of the data.

THIRD. The entity HISPAPOST formalized a contract with the entity CI POSTAL, under which the latter is obliged to cover the distribution of ordinary mail in the city of Palma de Mallorca.

As a result of this contracting, on 10/01/2022, both entities signed the corresponding data processing agreement, which is declared reproduced in this act for evidentiary purposes. In this contract, among other issues, the types of data affected by the agreement, the categories of data subjects, and the processing operations are detailed.

It is also stipulated that HISPAPOST has the status of data processor, with CI POSTAL acting as a sub-processor and the client of HISPAPOST acting as the data controller of the data affected by the agreement.

Among the obligations assumed by CI POSTAL as a sub-processor are the following:

- Ensure that the persons authorized to process personal data commit expressly and in writing to respect confidentiality and comply with the corresponding security measures, of which they must be adequately informed.
- Ensure the necessary training in personal data protection for the authorized persons.
- Pursuant to Article 32 of the GDPR, CI POSTAL commits to adopt the necessary measures to prevent alteration, loss, unauthorized processing, or access to the personal data of HISPAPOST's clients, taking into account the state of technology, the nature of the data, and the risks involved, whether they arise from human action or from physical or natural means. CI POSTAL states that it has a Privacy Manual in which the technical and organizational measures to be implemented are determined.
- CI POSTAL will notify HISPAPOST without undue delay and as quickly as possible and in any case before 24 hours, via email to protecciondedatos@servinform.es, of any security breaches unless it is unlikely to pose a risk to the rights and freedoms of natural persons.
- It is the responsibility of HISPAPOST or its client (data controller) to notify the breaches to the AEPD and to the data subjects.
- According to the risk assessment carried out by HISPAPOST's client, and as established in Article 28 of the GDPR, CI POSTAL must implement at least the security measures corresponding to the medium level in accordance with the provisions of the regulation implementing the LOPD (RLOPD) RD 1720/2007, unless other measures are specified in its replacement.

FOURTH: The Local Police of the City Council of Palma de Mallorca, through a report dated 22/09/2022, informed this AEPD of the discovery of abandoned correspondence containing personal data, totaling 1,404 letters from the sending companies with the following distribution: La Caixa (596 letters), BBVA (57 letters), Naturgy (33 letters), Energía XXI (295 letters), Imagin (59 letters), Endesa (307 letters), MasMovil (1 letter), Telefax (3 letters), Totem (3 letters), Laboral Kutxa (1 letter), PSA (1 letter), Yoigo (1 letter), Orange (6 letters), Pra Group (1 letter), Jazztel (2 letters). These letters belonged to the months between February and May 2022.

According to the report, the documentation was found in a lot between the MA-30 and the train tracks, as reflected in ***REPORT.1 dated 02/07/2022.

In relation to this discovery of documentation, it is reported that the agents of the aforementioned Local Police contacted HISPAPOST, acknowledging that the found correspondence should have been delivered by employees of CI POSTAL, without knowing the reason why such delivery did not take place and the abandonment of the correspondence.

The letters in question were handed over by the Local Police to a representative of CI POSTAL on 22/09/2022. Previously, on 13/09/2022, this same person went to the Local Police premises and, when shown the found letters, recognized the logo of their company.

FIFTH. Through the Delegation of the Government of the Balearic Islands, on 17/11/2022, information prepared by the Superior Police Headquarters was received at the AEPD.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/38

Police of the Balearic Islands regarding the location, on 16/10/2022, of a total of 5354 abandoned letters in two different locations in Palma de Mallorca, for which the company HISPAPOST was responsible, executing the delivery through its subcontracted distributor CI POSTAL. The details of these letters, according to the sending entity, are recorded in the First Background of this act, which is declared reproduced for evidentiary purposes.

The discovery of part of this documentation (approximately 3000 letters) was reported to the National Police by a citizen, (...), who in turn received an email from a third party informing him of the existence of these communications in one of the city's torrents. According to reports, "the usable letters, unopened... were collected, leaving behind others that were totally or partially burned and others that were mixed with garbage."

The documentation provided by the Government Delegation includes another report of intervention by the National Police, dated 17/10/2022, regarding the discovery of numerous letters, the vast majority of which were sealed and some manipulated. They report on the statement of a witness, according to whom the letters had been in the location for approximately a week.

SIXTH. HISPAPOST, for its part, on 14/10/2024, filed a complaint with the National Police stating that "on 10 October 2022 HISPAPOST received a message from CI POSTAL in which they sent a video taken from Telegram showing a man commenting and filming thousands of letters scattered in a junkyard sent from HISPAPOST, which contain personal data of clients... that these letters were collected by the distributor in Mallorca on 11 October 2022 and were sent back on 13 October 2022 to the reporting company."

"On 13 October 2022, a message was received from CaixaBank informing that an individual identified as B.B.B. found approximately 4000 letters addressed to CaixaBank in perfect condition, which were thrown by an unknown individual from a vehicle at 19:00 on 10 October 2022."

Regarding the last reported incident, in an email dated 19/10/2022, sent by HISPAPOST to CAIXABANK, it is indicated:

"On 13/10/2022 we received a communication from CaixaBank, notifying that a person presented themselves at the CaixaBank office (...), indicating that they saw someone throwing correspondence in a location within the municipality. CaixaBank staff retrieved the shipments. On 14/10/2022 we went to the Territorial Directorate of Caixa in Palma de Mallorca, obtained the phone number of the person who initially informed CaixaBank of the location of the discovered documents, located the point where the correspondence appeared, and collected the remaining shipments from other clients not belonging to CaixaBank."

SEVENTH. In relation to the incident reported in Proven Fact Four, on 18/10/2022, the entity CI POSTAL prepared an evaluation report in which, among other circumstances, the following is expressed:

"1. The incident was intentional.

2. The origin of the incident has been internal (delivery personnel)...

4. As a consequence of the incident, individuals or organizations that are not authorized, or do not have a legitimate purpose to access the data, have been able to access it.

5. Specifically referring to the affected data (names and postal addresses), they are NOT protected in such a way that they are readable by anyone who may have had access, and individuals can be identified...

10. It is unknown whether there are minors among the affected individuals, as well as vulnerable groups (victims of gender-based violence or at risk of social exclusion).

11. It is estimated that the number of recovered letters does not exceed 2,000 units.

EIGHTH. The entity CI POSTAL, in its responses to this AEPD, has referred to the preventive measures it had implemented. Among the details provided, the following information stands out:

“As a postal delivery company, the measures aimed at preventing the risks arising from the abandonment or non-delivery of correspondence are focused on the training and commitment of the workforce beyond the implementation of technological solutions” (the personnel are required to sign a confidentiality commitment), in addition to informative communications about the responsibility of not delivering notifications or letters and/or misusing them (provides a communication dated 19/11/2021).

“In the process of onboarding workers, a welcome pack is provided with a compendium of rules and protocols that must be complied with” (Code of Ethics and Conduct, implemented on April 16, 2018; corporate policies with obligations and prohibited conduct, implemented on April 16, 2018; description of the Whistleblower Channel, implemented on April 16, 2018; Disciplinary and Sanctioning Regime, implemented on April 16, 2018; and Protocol for Delivery Personnel, implemented on October 20, 2020).

In relation to the accreditation of the measures adopted to ensure traceability and follow-up of shipments, CI POSTAL reported as follows: “In ordinary postal delivery, the cause of the security incident due to abandonment of correspondence, implementing traceability and follow-up measures for delivery involves a very high level of difficulty. To date, no technological solution has been found that allows confirmation that ordinary mail has been deposited in the mailbox. It should be noted that CI POSTAL receives large volumes of correspondence from its clients for delivery, without any breakdown of data. Only batches of correspondence are delivered to us where the only data available is the number of letters to be delivered. Creating delivery teams of two people to control whether the delivery is made or not is an unfeasible solution due to costs.”

NINTH. The entity CI POSTAL, in its responses to this AEPD, has referred to the reactive measures and actions taken in response to the incidents noted in the previous Established Facts in order to prevent them in the future:

- “Firstly, the workers involved in the incident were dismissed, and the rest of the staff was gathered to remind them of their obligations regarding the custody of correspondence and the consequences of non-compliance.

- New training has been conducted to serve as a reinforcement for the prevention of similar incidents.

- A reminder to all classification and delivery personnel through meetings and individualized writings regarding the legal repercussions of retaining, storing, concealing, opening, or destroying any postal shipment.

- Monitoring of the delivery personnel regarding their work, asking about the streets where they were delivering and verifying this with the deliveries we have prepared.”

“We are studying and evaluating whether there is any type of technological solution that allows confirmation that the mail has been deposited in a mailbox. The training and awareness plan for the work team has been strengthened to avoid future incidents.”

“...a privacy training manual has been incorporated that includes basic concepts for their functions,

considering that delivery personnel in 99% of cases handle data in a consultative manner, without the capacity to record, modify, or delete data.”

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, by the general rules on administrative procedures.”

II

Preliminary Issues

Article 4 of the GDPR establishes that:

For the purposes of this Regulation, the following shall be understood as:

1) “personal data”: any information relating to an identified or identifiable natural person (“the data subject”); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.

25/38

a person whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person;

In point 2 of the same article, the concept of “processing” of personal data is defined.

2) “processing”: any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or modification, extraction, consultation, use, communication by transmission, dissemination, or any other form of enabling access, comparison, or interconnection, restriction, erasure, or destruction;

In the present case and in accordance with the report from the LOCAL POLICE, dated September 22, 2022, it is revealed that a total of 1,404 letters containing personal data (name and surname, and postal address) were found in an abandoned lot, with the logo of the company HISPAPOST, which was contacted by the LOCAL POLICE agents, recognizing that the found correspondence should have been delivered by employees of CI POSTAL, without understanding the reason why this delivery was not carried out and the correspondence was abandoned.

Subsequently, a new complaint was received from the Government Delegation in the Balearic Islands, which forwarded a letter sent by the Superior Police Headquarters of the Balearic Islands regarding the location of a total of 5,354 letters abandoned in two different locations in La Palma, for which the company HISPAPOST was responsible, managing the delivery through its distributor in La Palma, CI POSTAL SL.

It is therefore pertinent to analyze whether the processing of personal data carried out is in accordance with the provisions of the GDPR.

In Article 4 of the GDPR, points 7 and 8 specify what is to be understood by the data controller and the data processor. Thus we have:

“7) ‘data controller’ or ‘controller’ means the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided by the law of the Union or of the

Member States;

8) 'data processor' or 'processor' means the natural or legal person, public authority, agency, or other body which processes personal data on behalf of the controller..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/38

In short, the data controller is the natural or legal person or public authority that decides on the processing of personal data, determining the purposes and means of such processing.

By virtue of the principle of proactive responsibility, the data controller must implement technical and organizational measures to comply with and be able to demonstrate compliance, taking into account the risk involved in the processing of personal data.

On the other hand, the data processor is the natural or legal person, public authority, service, or other body that provides a service to the controller that involves the processing of personal data on behalf of the controller.

In this sense, the controller is the one who decides the "why" and "how" regarding personal data, and the processor is the one who carries out the processing on behalf of the controller.

The role of the data processor in the GDPR is defined in Article 28, which establishes the requirements that must be met regarding data protection:

1. When processing is to be carried out on behalf of a data controller, the controller shall choose only a processor that provides sufficient guarantees to implement appropriate technical and organizational measures, so that the processing is in compliance with the requirements of this Regulation and ensures the protection of the rights of the data subject.

2. The data processor shall not engage another processor without the prior written authorization, specific or general, of the controller. In the latter case, the processor shall inform the controller of any intended changes concerning the incorporation or replacement of other processors, thus giving the controller the opportunity to object to such changes.

3. The processing by the processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller and establishes the subject matter, duration, nature, and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. Such contract or legal act shall stipulate, in particular, that the processor:

a) shall process the personal data only on documented instructions from the controller, including with regard to the transfers of personal data to a third country or an international organization, unless required to do so by Union or Member State law applicable to the processor; in such a case, the processor shall inform the controller of that legal requirement before the processing, unless that law prohibits such information on important grounds of public interest;

b) shall ensure that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;

c) shall take all necessary measures in accordance with Article 32; (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/38

4. When a data processor engages another processor to carry out certain processing activities on behalf of the controller, the same data protection obligations imposed on the initial processor by the contract or other legal act established in accordance with Union or Member State law shall be imposed on this other processor, particularly the provision of sufficient guarantees for the implementation of appropriate technical and organizational measures so that the processing is in compliance with the provisions of this Regulation. If that other processor fails to fulfill its data protection obligations, the

initial processor shall remain fully liable to the controller for compliance with the obligations of the other processor. (...).

10. Without prejudice to the provisions of Articles 82, 83, and 84, if a data processor infringes this Regulation by determining the purposes and means of processing, it shall be considered a controller with respect to that processing. (...).

These specific obligations may be supervised by data protection authorities, without prejudice to the oversight that may be carried out regarding compliance with the GDPR or the LOPDGDD by the controller or the data processor.

From the actions taken, it has been established that the breach had as its entry vector the negligent action of one or more disloyal employees of the company CI POSTAL, a delivery company acting as a sub-processor for HISPAPOST, which at the same time acted as a processor for other multiple responsible (or processing) entities of the personal data contained in the abandoned letters.

CI POSTAL has processed personal data in a manner incompatible with the processing framework, as determined by HISPAPOST. Therefore, in accordance with Article 28, paragraph 10, of the GDPR, CI POSTAL, as a processor of HISPAPOST, must, in this case, be considered a controller of personal data with respect to that processing.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f) of Article 5 of the GDPR. For its part, the security of personal data is regulated in Article 32 of the GDPR, which governs the security of processing.

III

Article 5.1.f) of the GDPR

The facts revealed consist of the existence of several personal data breaches resulting from the abandonment in public spaces, by employees of the entity CI POSTAL, of postal correspondence whose delivery was to be carried out by that entity under the contracts formalized by it.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/38

with HISPAPOST. This allowed unauthorized access by third parties to the personal data relating to the recipients of the shipments, specifically their name and full postal address.

Regarding these facts, CI POSTAL acts as the data controller, as stated in the previous section. As such, it is obligated to demonstrate compliance with the GDPR and the LOPDGDD and to implement the technical and organizational measures that ensure the security of personal data when processing it, in accordance with the provisions of Article 5.1.f) of the GDPR, which states:

“Article 5 Principles relating to processing:

1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures (‘integrity and confidentiality’).”

In relation to this principle, Recital 39 of the aforementioned GDPR states:

“[...] Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and of the equipment used for processing.”

The documentation in the file provides sufficient evidence that CI POSTAL violated Article 5.1 of the GDPR, principles relating to processing, when a personal data breach occurred as a result of the actions of one or more disloyal employees of CI POSTAL, failing to adequately ensure the confidentiality and integrity of the data.

In this regard, the aforementioned Article 5.1.f) of the GDPR provides that personal data shall be processed in a manner that ensures its security, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures.

The loss of confidentiality poses a risk that may lead to material or immaterial damages for individuals (Recital 85 of the GDPR). In this sense, Recital 75 of the GDPR establishes that: "Risks to the rights and freedoms of natural persons, of varying severity and likelihood, may arise from the processing of data that could cause physical, material or immaterial damage, particularly in cases where processing could lead to discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; ...".

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/38

Therefore, unauthorized access to personal data implies that such data may be used for unknown purposes, including fraudulent ones, resulting in a total and absolute loss of control over them.

In this same sense, Article 28.2 of the LOPDGDD, regarding the obligations of the data controller within the framework of Articles 24 and 25 of the GDPR to ensure and demonstrate that the processing is compliant with the GDPR concerning various risks, states that:

"2. For the adoption of the measures referred to in the previous paragraph, the controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to the affected individuals. ..."

And the Judgment of the Constitutional Court (STC) 292/2000 in the seventh legal foundation states:

"... it turns out that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that empowers the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which this third party may collect, and that also allows the individual to know who holds that personal data and for what purpose, being able to oppose such possession or use. These powers of disposition and control over personal data, which are part of the content of the fundamental right to data protection, are legally specified in the ability to consent to the collection, obtaining, and access to personal data, its subsequent storage and processing, as well as its possible use or uses by a third party, whether the State or a private individual."

In the present case, it has been established that there were several shipments of letters that were not delivered to their recipients and, instead, were discarded in public spaces, according to the details recorded in the proven facts of this resolution, affecting thousands of shipments.

The abandonment of these letters in an open area containing personal data (name and surname, and postal address) allowed, in some cases, unauthorized access by third parties, and in other cases, their unauthorized destruction or accidental damage, violating the principles of confidentiality and integrity, both established in Article 5.1.f) of the GDPR.

All of this has been acknowledged by the entity CI POSTAL itself.

In light of the above, the events that occurred are considered to constitute an infringement, attributable to CI POSTAL, for violation of Article 5.1.f) of the GDPR.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

C/ Jorge Juan, 6

www.aepd.es

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that:

“Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall be subject to a three-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

V

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is necessary to assess the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR.

As aggravating factors:

- b) the intent or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, particular emphasis must be placed on the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

It is also considered appropriate to adjust the sanction to be imposed according to the criteria established in section 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As aggravating factors:

-

b) The link between the infringer's activity and the processing of personal data.

CI POSTAL is dedicated to the transportation and delivery of all kinds of goods and information, which involves the processing of personal data of clients and recipients.

Consequently, for the purpose of complying with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations on personal data protection.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the

LOPDGDD, with respect to the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for the imposition of a sanction of €120,000 (ONE HUNDRED TWENTY THOUSAND EUROS).

VI

Article 32 of the GDPR

Regarding the application of data protection regulations to the case presented, it should be noted that the GDPR, in its Article 32, requires data controllers and processors to adopt the necessary security measures to ensure that the processing is in accordance with the current regulations, as well as to ensure that any person acting under the authority of the controller or the processor and having access to personal data can only process such data following the instructions of the controller.

Article 32 of the GDPR, regarding the security of processing, states the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data can only process such data following the instructions of the controller, unless required to do so by Union or Member State law.”

The GDPR defines personal data security breaches as “all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

The documentation in the file evidences the violation of Article 32.1 of the GDPR, as a consequence of the lack of appropriate technical and organizational measures to ensure a level of security adequate to the risk of processing.

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather establishes that the controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and a verification process (which is not an audit), assessment, and evaluation of the effectiveness of the measures.

In any case, when assessing the appropriateness of the level of security to the risk, particular consideration shall be given to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/38

unauthorized access to such data that could cause physical, material, or immaterial damages.

In this same regard, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the costs of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial damages.”

To ensure these security factors, both technical and organizational measures are necessary that are appropriate to achieve a level of security commensurate with the risk.

In the present case, it is evident that the security measures that the data controller had implemented concerning the data being processed were inadequate, regardless of the breach.

When referring to the preventive measures that were in place at the time the letters were abandoned, CI POSTAL, beyond the confidentiality commitment it requires from its employees and the information it provides about its internal protocols or informative communications regarding its responsibilities, does not include any security measures actually adopted to prevent such incidents as much as possible.

Thus, in this case, there is evidence of the absence of technical and organizational measures by CI POSTAL that guarantee an adequate level of security commensurate with the risk, as it did not have a system to verify that the letters reached their recipients nor had it provided its employees with any specific instructions on how to deliver the letters to comply with the regulations on personal data protection, except for a one-hour training session at the beginning of the employment relationship.

There was no subsequent verification, audits, or sampling.

On the contrary, in its response to the inspection services of this AEPD, regarding the accreditation of the measures adopted to ensure traceability and tracking of shipments, CI POSTAL admitted not having any control system, justifying this fact as follows: “In ordinary postal delivery, the cause of the security incident due to the abandonment of correspondence, implementing traceability and tracking measures for delivery entails a very high level of difficulty. To date, no technological solution has been found that allows for confirmation that ordinary mail has been deposited in the mailbox. It should be noted that CIPOSTAL receives from its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/38

large clients with high volumes of correspondence to distribute, without any data breakdown. We are only provided with batches of correspondence where the only information available is the number of letters to be distributed. Creating delivery teams of two people to control whether the distribution is carried out or not is an unfeasible solution due to costs.”

The GDPR also requires not only the design of the necessary technical and organizational means but also their proper implementation and appropriate use, so that it will also be liable for the lack of

diligence in their use, understood as reasonable diligence considering the circumstances of the case. In short, the responsibility of the respondent is determined by the inadequacy of the technical and organizational security measures revealed, as it is responsible for making decisions aimed at effectively implementing appropriate measures to ensure a level of security adequate to the risk, including those aimed at restoring availability and preventing access to data in the event of a physical or technical incident. However, from the documentation provided, it is evident that the entity fails to comply with this obligation, as the implemented procedures do not verify compliance with the mandate. It must be emphasized that the adequacy of the level of security to the risk must be evaluated by the responsible party and reconsidered periodically based on the results obtained, taking into account - among other factors - the risks that may arise from the unauthorized communication of such data. The technical and organizational security measures that must be applied are those relevant to respond to the existing risk, assessing, among other factors, the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probability and severity risks to the rights and freedoms of the data subjects.

One of the requirements established by the GDPR for data controllers and processors conducting processing activities with personal data is the need to carry out a risk analysis of information security in order to establish security and control measures aimed at complying with the principles of protection by design and by default that guarantee the rights and freedoms of individuals.

This lack of adequate security measures that leads to the infringement of Article 32.1 constitutes an infringement in itself, considered independently of the detected security incidents and personal data breaches.

In accordance with the above, it is considered that the known facts constitute an infringement attributable to the reported entity for violation of Article 32 of the GDPR.

IV

Classification of the infringement of Article 32 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/38

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations:

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.

V

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is appropriate to grade the sanction to be imposed in accordance with the criteria established in Article 83.2 of the GDPR.

It is also considered appropriate to grade the sanction to be imposed in accordance with the criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- b) The link of the infringer's activity with the processing of personal data.

CI POSTAL is engaged in the transportation and delivery of all kinds of goods and information, which implies the processing of personal data of customers and recipients.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/38

As a result, and for the purpose of complying with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations regarding the protection of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions established in Article 32 of the GDPR, allows for the imposition of a fine of €80,000 (EIGHTY THOUSAND EUROS).

V

Adoption of Measures

Infringements in this matter may lead to the imposition on the responsible party of the obligation to adopt appropriate measures to align their actions with the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, which states that each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified timeframe...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

Thus, this Agency may require the responsible entity to, within the timeframe determined, adjust its actions to the personal data protection regulations, to the extent expressed in the Legal Grounds of this agreement.

This act establishes the infringements committed and the facts that lead to the violation of the data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

During the proceedings prior to the initiation of the sanctioning procedure, CI POSTAL has communicated to this AEPD the corrective measures it adopted in connection with the security and confidentiality incidents subject to the file, among which are the dismissal of the involved employees, the provision of new training for employees, the preparation of a privacy manual, and the sending of reminders to them regarding the legal repercussions of retaining postal shipments.

The validity of these measures is not questioned, but they are declared insufficient to the extent that none of them contemplate the establishment of mechanisms aimed at ensuring the effective delivery of letters to their recipients, preventing them from being deposited in an inappropriate location, except for the measure that includes monitoring the delivery personnel, which, on the other hand, is not adequately explained.

Consequently, it is appropriate to require CI POSTAL to, within a period of six months from the date of the enforceability of this sanctioning resolution, adopt

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/38

the technical and organizational measures of all kinds, including appropriate security measures to ensure a level of security adequate to the risk, in order to comply with the provisions established in articles 5.1.f) and 32 of the GDPR.

By way of indication, among the measures to be adopted, those aimed at ensuring control over postal deliveries may be considered, establishing a viable system for verifying the traceability of the letters sent, control over returns, tracking of complaints, measurements, conducting periodic inspections in the distribution network, internal audits, establishment of quality management models, circulation of test shipments, or the implementation of internal or external panels.

It is warned that failure to comply with the order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on CORREO INTELIGENTE POSTAL, S.L., with NIF B95604021,

- For the infringement of article 5.1.f) of the GDPR, classified in article 83.5 of said regulation, an administrative fine of 120,000.00 euros.

- For the infringement of article 32 of the GDPR, classified in article 83.4 of said regulation, an administrative fine of 80,000.00 euros.

SECOND: TO ORDER CORREO INTELIGENTE POSTAL, S.L., with NIF B95604021, that pursuant to article 58.2.d) of the GDPR, within six months from the date this resolution becomes final and enforceable, to demonstrate compliance with the following security measures:

- A system for verifying the traceability of the letters sent.
- Specific instructions for employees indicating how to deliver the letters in a manner that complies with personal data regulations.

THIRD: TO NOTIFY this resolution to CORREO INTELIGENTE POSTAL, S.L.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has elapsed without the interested party having exercised this right.

The sanctioned party is warned that they must fulfill the imposed sanction once this resolution is enforceable, in accordance with the provisions of article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/38

Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receiving the notification and once it is executive, if the date of executive status falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public

once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es